

Privacy Policy

DRAFT for review — not yet published. Requires legal review before publication.

Last updated: 2026-08-14 **Version:** 1.0 (draft)

This Privacy Policy explains how we collect, use, share and protect your personal data when you use our personal finance app, Sorted. It is written for UK residents aged 18 or over. Please read it alongside any in-app consent screens you are shown when you connect a bank account.

1. Who we are

Sorted is provided by AURIQ LTD, a company registered in England and Wales under company number 16813875, trading as "Sorted".

- **Registered address:** Birmingham, B36, United Kingdom (full registered office address is available on the Companies House register under company number 16813875)
- **Contact:** kevin.maingi@auriqltd.co.uk
- **ICO registration:** ZC214737

AURIQ LTD is the data controller for the personal data described in this policy — we decide what data is collected and why.

We provide an account information service (AIS): a personal finance dashboard that shows you your own bank data — spending categorisation, budgets, upcoming bills, debt payoff tracking and savings insights — in one place. **We never initiate payments and we never move your money.** We only read data from accounts you choose to connect.

2. What data we collect

We collect the following categories of data:

1. **Account details** — your name and email address, obtained when you sign in with Google.
2. **Open banking data** — account names, account types, balances, and transactions (date, amount, description, merchant) from the bank accounts you choose to connect.
3. **Postcode** — if you provide it during onboarding, so we can show you location-relevant information. This is optional.
4. **Documents you choose to upload** — such as bank or investment statements, and receipt photos.
5. **In-app chat content** — the messages you send to, and receive from, our AI assistant.
6. **Device push notification tokens** — so we can deliver notifications to your phone.
7. **Basic technical and security logs** — for example, records needed to detect and prevent fraud or abuse of the service.

We do not collect special category data (such as health or biometric data) as part of the service.

3. How we use your data and our lawful bases

We use your data to provide, secure and improve the service. Under UK GDPR, we rely on the following lawful bases:

- **Explicit consent** — for accessing your open banking data (account and transaction information) via our banking data providers. You give this consent when you connect a bank account, and you can withdraw it at any time (see Section 4 and Section 9).
- **Performance of a contract** — for the core functionality of the app: showing your accounts, categorising spending, building budgets, tracking bills, debt and savings, and providing the AI assistant, once you have connected a bank account or created an account with us.
- **Legitimate interests** — for security, fraud prevention and improving the service (for example, understanding which features are used so we can make the app more reliable and useful). We only rely on this basis where our interests are not overridden by your rights and interests.

We do not use your data for marketing purposes, and we do not use your open banking data for advertising.

4. Open banking and your consent

To show you your accounts, balances and transactions, we connect to your bank using regulated open banking infrastructure. This works as follows:

- **Our regulated status.** We are a registered agent of Finexer LTD, an FCA-authorised firm, and provide the regulated account information service to you through this agency arrangement. All bank connections are made through Finexer.
- **Your consent.** When you connect a bank account, you give explicit consent to access your account and transaction data, in line with the second Payment Services Directive (PSD2). We only access data covered by that consent.
- **Consent renewal.** Under PSD2, this consent is time-limited and must be reconfirmed with your bank approximately every 90 days. We'll prompt you to reconfirm before it expires; if you don't, we stop retrieving new data from that account until you reconnect.
- **Historical data.** On first connection, we retrieve approximately 90 days of transaction history, as permitted by your consent. After that, we retrieve only new transactions incrementally.
- **Withdrawing consent.** You can withdraw consent and disconnect a bank account at any time from within the app — see Section 9 for what happens next.

5. AI processing

We use AI to categorise your transactions and generate insights (for example, spend summaries, budget suggestions and answers in the in-app chat assistant). We are specific about what we send and why:

- **What we send.** For categorisation, we send the merchant name, a truncated transaction description, the transaction amount and direction (in/out), and your name. Your name is included only so that transfers between your own accounts are not mistaken for income.

- **What we never send.** We do not send account numbers, sort codes, IBANs or card numbers to any AI provider.
- **No training on your data.** Our AI requests are routed through an AI gateway (OpenRouter) to underlying model providers (which may include Amazon Bedrock, Google, Anthropic or Microsoft Azure). Requests are sent with a data-collection "deny" preference, and neither our gateway nor the underlying providers train their models on your inputs or outputs.
- **Chat.** If you use the in-app AI assistant, the content of your conversation is processed to generate a response, and is retained only for a short period (see Section 8).

6. Who we share data with

We share data with the following sub-processors, who process it on our behalf under contract, only to the extent needed to provide the service:

Sub-processor	Purpose
Finexer LTD	Open banking connectivity (regulated account information services)
MongoDB Atlas	Database hosting (EU, Frankfurt)
Railway	Application hosting (EU West)
Vercel	Web hosting
Cloudflare R2	Storage of encrypted backups
GitHub	Runs our automated nightly backup job
OpenRouter	AI gateway, routing to Amazon Bedrock, Google, Anthropic or Microsoft Azure, for transaction categorisation and insights
Tavily	Web search, used for merchant and product identification
Logo.dev	Provides brand logos; receives brand domain names only, never customer data
postcodes.io	Converts a postcode to an approximate location
Google	Sign-in, and push notification delivery on Android
Apple	Push notification delivery on iOS
Expo	Push notification delivery relay
Sentry	Error monitoring (only if enabled)

We do not sell your data to anyone, and we do not share your data for advertising or marketing purposes. We do not use advertising or tracking SDKs in our apps.

We may also disclose data where required by law, for example in response to a valid request from a regulator or law enforcement body.

7. International transfers

Our database and application hosting are located in the EU, which is covered by the UK's data adequacy regulations, so no additional safeguard is required for those transfers.

Some AI providers we use (see Section 5 and Section 6) process data in the United States. Where this happens, the transfer is protected under the UK International Data Transfer Agreement (IDTA) or the EU Standard Contractual Clauses with the UK Addendum, as appropriate.

8. How long we keep data

We keep data only as long as necessary for the purposes described in this policy:

Data	Retention period
Account and transaction data	Deleted within 30 days of account closure, consent withdrawal, or bank disconnection
Dormant accounts (no activity)	Deleted after 12 months of inactivity
Consent records	Kept for 12 months after the connection ends, for audit purposes
Chat sessions	7 days
Webhook logs	30 days
Insight caches	30 days
Encrypted backups	Rolling 30-day window

9. How to delete your data

You're in control of your data at all times, directly in the app:

- **Disconnect a bank account** — deletes the accounts and transactions from that connection, and revokes the underlying consent with the banking data provider.
- **Delete your account** — erases your records across all our systems, subject to the retention periods in Section 8 (for example, backups roll off on a 30-day cycle, and consent records are kept 12 months for audit purposes as required by regulation).

You don't need to contact us to exercise either option, though you're welcome to email us if you'd like help.

10. Your rights

Under UK GDPR, you have the right to:

- **Access** the personal data we hold about you.
- **Rectification** of inaccurate or incomplete data.

- **Erasure** of your data ("the right to be forgotten").
- **Restriction** of how we process your data in certain circumstances.
- **Portability** — to receive your data in a structured, commonly used format.
- **Object** to processing based on legitimate interests.
- **Withdraw consent** to open banking data access at any time, without affecting the lawfulness of processing before withdrawal.
- **Complain to the ICO** — see Section 15.

To exercise any of these rights, email us at kevin.maingi@auriq ltd.co.uk. We will respond within one month.

11. Security

We take the security of your data seriously:

- Bank access tokens are encrypted at rest using AES encryption.
- Data is encrypted in transit using TLS.
- Access to your data is controlled and limited to what is needed to operate the service.
- Backups are encrypted and taken nightly.

12. Cookies

We use only essential cookies and local storage, needed to keep you signed in and to operate the app. We do not use advertising or analytics cookies, and we do not track you across other websites or apps.

13. Children

Sorted is intended for UK residents aged 18 or over. We do not knowingly collect data from anyone under 18. If you believe a child has provided us with personal data, please contact us and we will delete it.

14. Changes to this policy

We may update this policy from time to time, for example to reflect changes in the service or in the law. We will update the "Last updated" date at the top of this page when we do. If we make a material change, we will take reasonable steps to let you know, such as an in-app notice.

15. How to contact us and how to complain

If you have any questions about this policy or how we handle your data, or want to exercise any of your rights, contact us at:

AURIQ LTD (trading as Sorted) Email: kevin.maingi@auriq ltd.co.uk Registered address: Birmingham, B36, United Kingdom ICO registration: ZC214737

If you are unhappy with how we have handled your data, you have the right to complain to the UK's data protection regulator, the Information Commissioner's Office (ICO):

Information Commissioner's Office Website: ico.org.uk Telephone: 0303 123 1113

We would appreciate the chance to address your concerns directly before you contact the ICO, but you are free to contact them at any time.